THOMSON COURSE TECHNOLOGY

Guide to Network Defense and Countermeasures Third Edition

Chapter 10

Firewall Design and Management

Objectives

- Design common firewall configurations
- Describe, install, and configure a proxy server
- Describe and plan the configuration of a bastion host
- Describe and plan the configuration of a honeypot
- Describe and configure Network Address Translation
- Perform basic configuration of a Cisco ASA firewall

© Cengage Learning 2014

Designing Firewall Configurations

- Firewalls can be deployed in several ways
  - As part of a screening router
  - Dual-homed host
  - Screen host
  - Screened subnet DMZ
  - Multiple DMZs
  - Multiple firewalls
  - Reverse firewall

© Cengage Learning 2014

Screening Routers

- Screening router
  - Determines whether to allow or deny packets based on their source and destination IP addresses
    - Or other information in their headers
  - Does not stop many attacks
    - Especially those that use spoofed or manipulated IP address information
  - Should be combined with a firewall or proxy server
    - For additional protection

© Cengage Learning 2014

A Screening Router

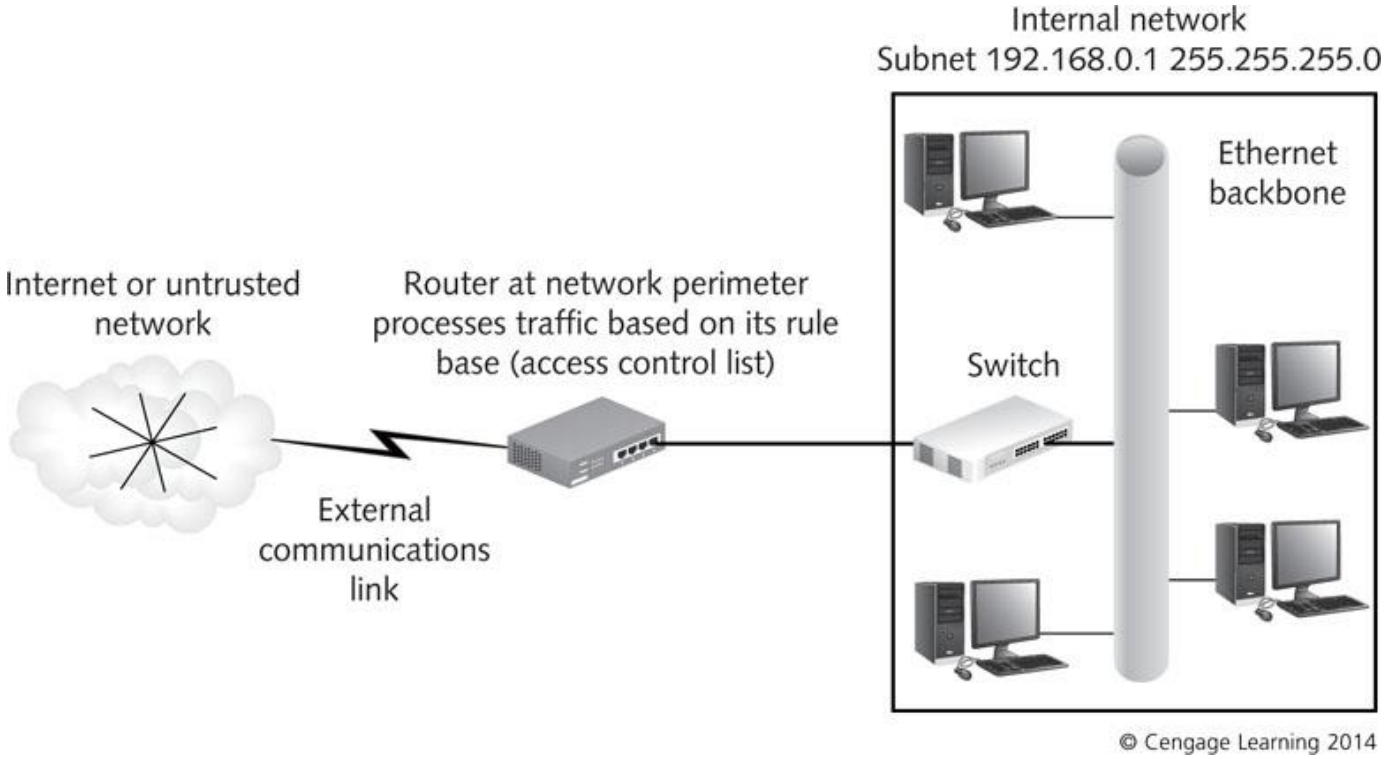


Figure 10-1 A screening router

Dual-Homed Hosts

- Dual-homed host
  - Computer that has been configured with more than one network interface
  - Only firewall software can forward packets from one interface to another
  - Firewall is placed between the network and Internet
  - Provides limited security because firewall depends on same computer used for day-to-day communication
  - Host serves as a single point of entry to the organization
    - Attackers only have to break through one layer of protection

© Cengage Learning 2014

A Dual-Homed Host

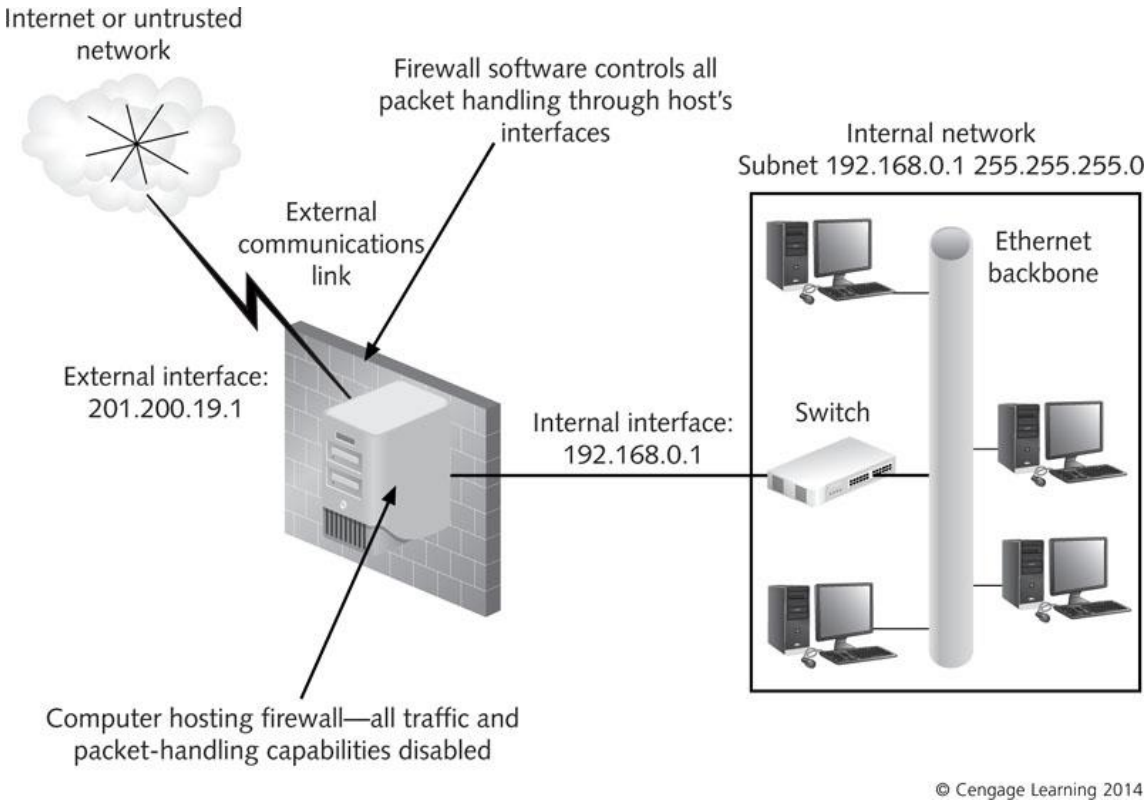


Figure 10-2 A dual-homed host

Screened Hosts

- Screened host
  - Similar to a dual-homed host except router is added between the host and the Internet
    - To carry out IP packet filtering
  - Combines a dual-homed host and a screening router
  - Might choose this setup for perimeter security on a corporate network
  - Can function as an application gateway or proxy server

© Cengage Learning 2014

A Screened Host

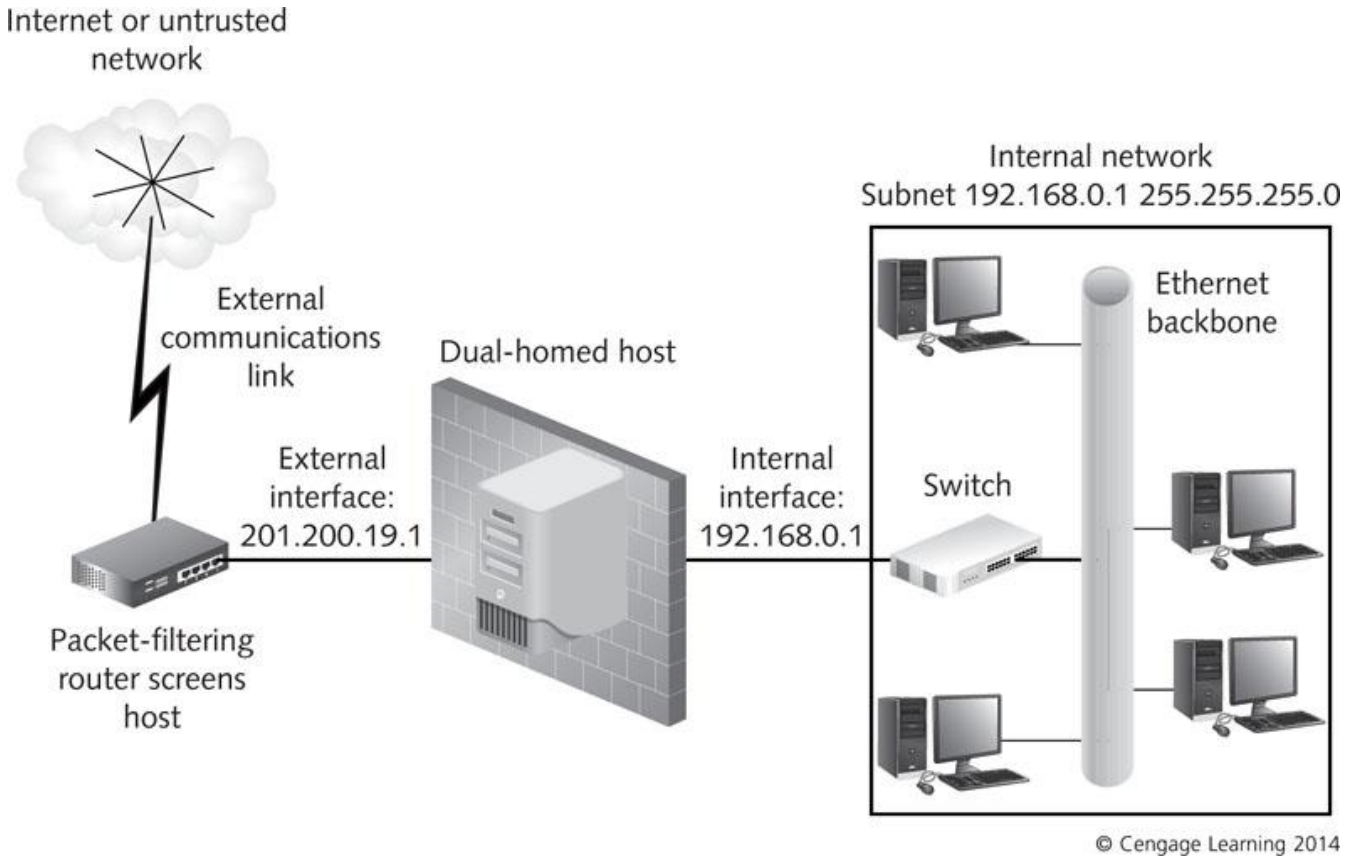


Figure 10-3 A screened host

Screened Subnet DMZs

- DMZ
  - Subnet of publicly accessible servers placed outside the internal LAN
  - Common solution is to make servers a subnet of the firewall
- Firewall that protects the DMZ is connected to the Internet and the internal network
  - Called a three-pronged firewall
- Might choose this setup when you need to provide services to the public

© Cengage Learning 2014

A Screened Subnet DMZ

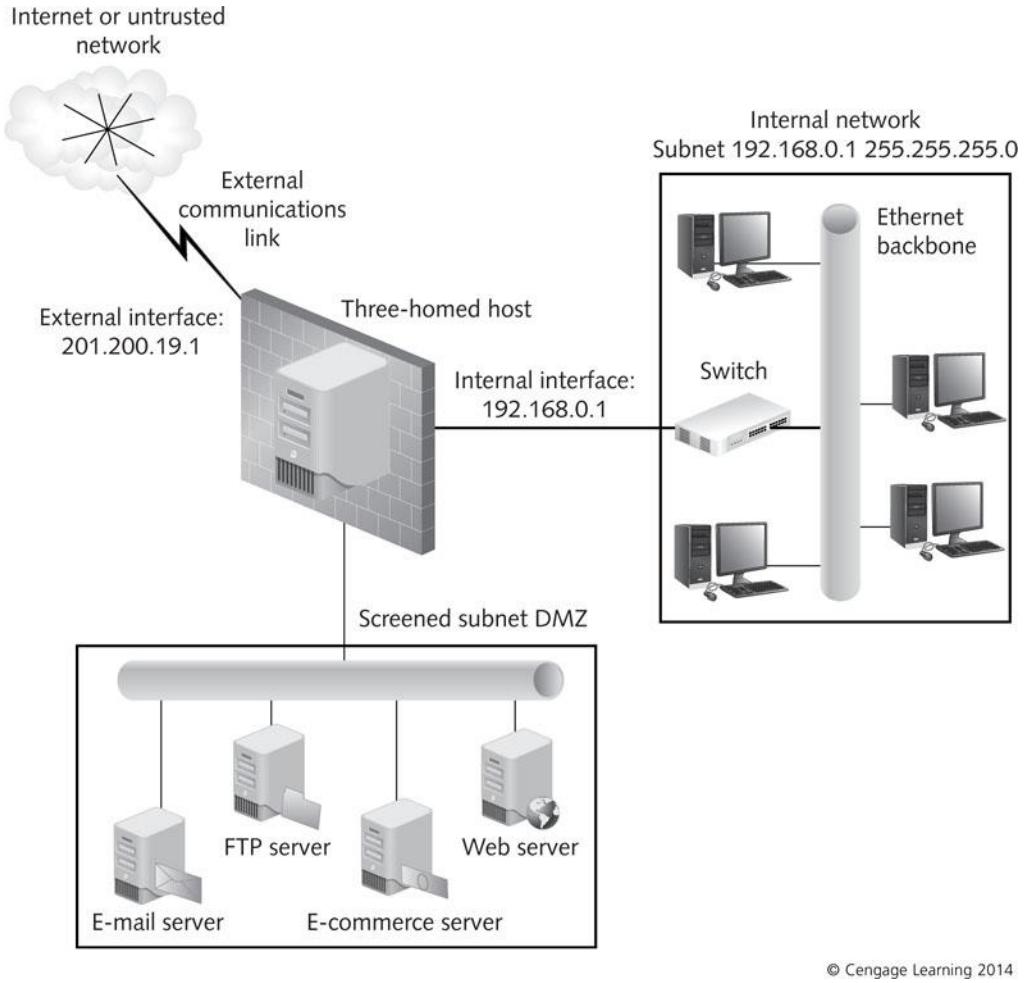


Figure 10-4 A screened subnet DMZ

Multiple DMZ/Firewall Configurations

- **Server farm**
  - Group of servers connected in their own subnet
  - Work together to receive requests with the help of load-balancing software
- **Load-balancing software**
  - Prioritizes and schedules requests and distributes them to servers
- Clusters of servers in DMZs help protect the internal network from becoming overloaded
- Each server farm/DMZ can be protected with its own firewall or packet filter

© Cengage Learning 2014

Multiple DMZs Protected by Multiple Firewalls

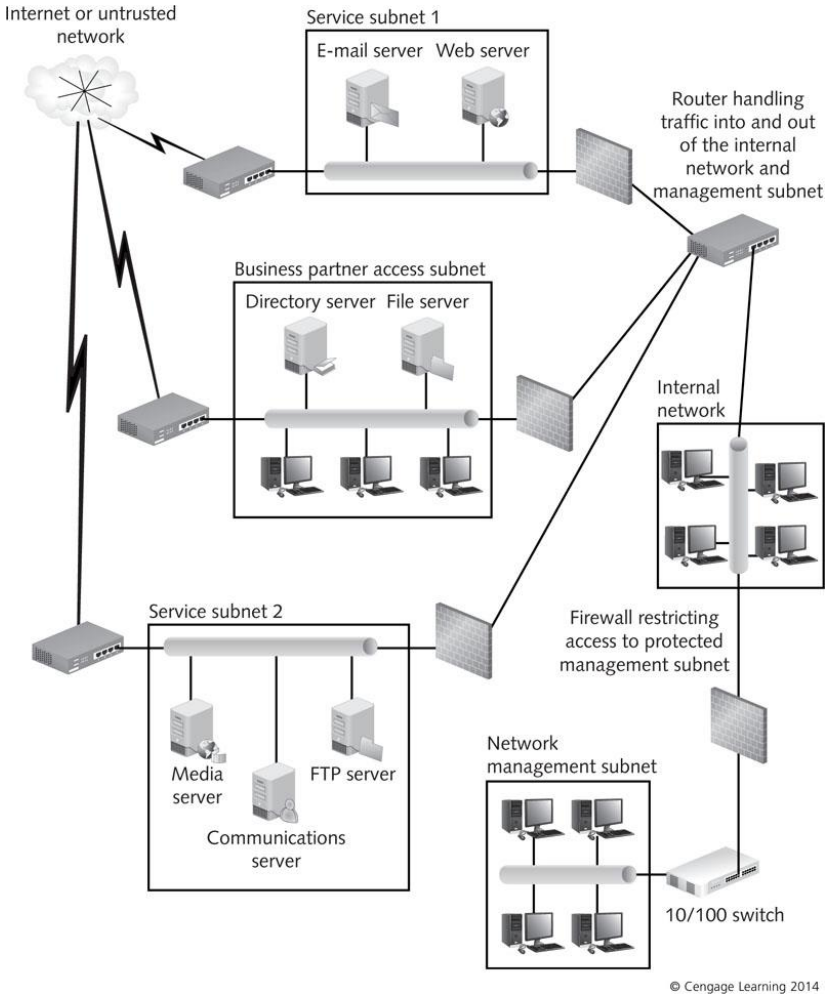


Figure 10-5 Multiple DMZs protected by multiple firewalls

Multiple Firewall Configurations, Part 1

- Many organizations find they need more than one firewall
- Protecting a DMZ with Multiple Firewalls
  - Must be configured identically and use same software
  - One firewall controls traffic between DMZ and Internet
  - Second firewall controls traffic between protected network and DMZ
    - Can also serve as a **failover firewall** (backup if one fails)
  - Advantage
    - Can control where traffic goes in the three networks you are dealing with

© Cengage Learning 2014

Two Firewalls Used for Load Balancing

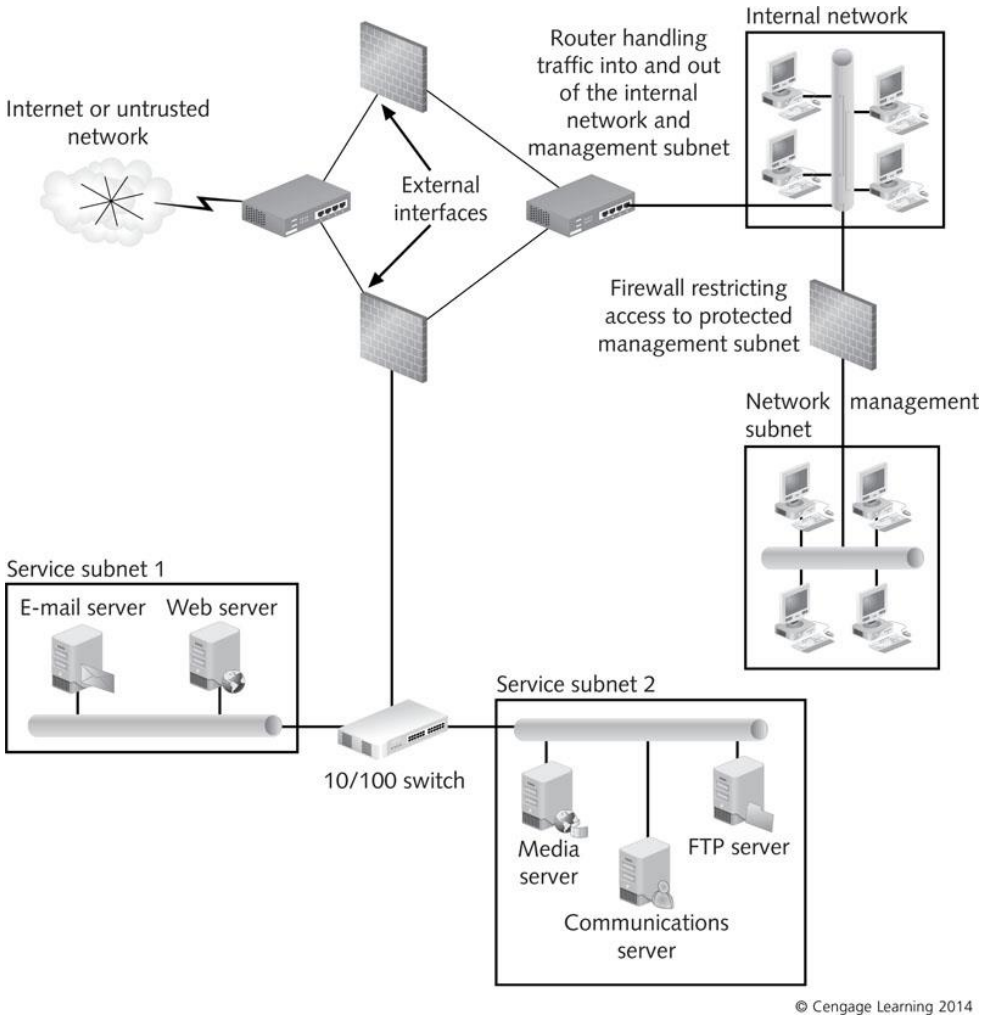


Figure 10-6 Two firewalls used for load balancing

Multiple Firewall Configurations, Part 2

- Protecting Branch Offices with Multiple Firewalls
  - Multiple firewalls can implement a single security policy
  - Main office has a centralized firewall
    - Directs traffic for branch offices and their firewalls
    - Develops security policy and deploys it through firewall using a security workstation
  - Each branch office has its own firewall
    - Security policy from main office is copied to every firewall

© Cengage Learning 2014

Multiple Firewalls Protecting Branch Offices

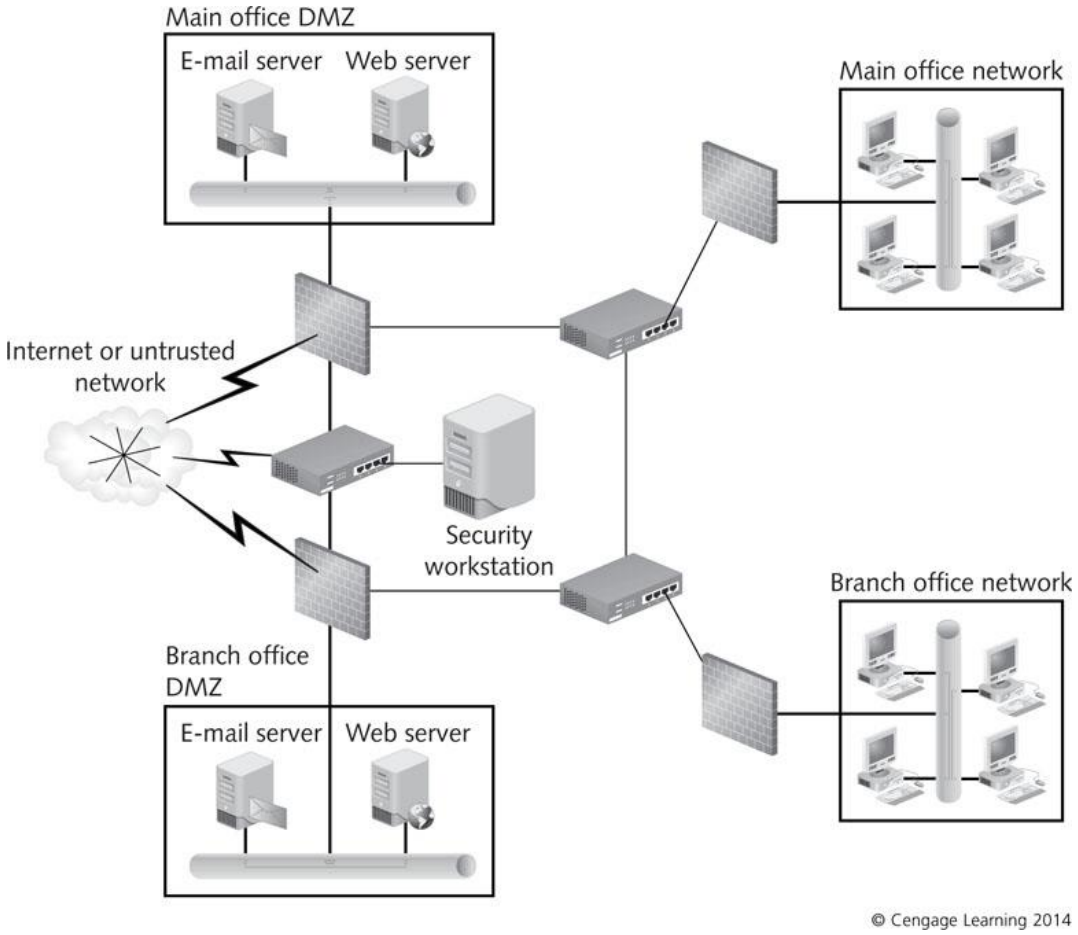


Figure 10-7 Multiple firewalls protecting branch offices

Reverse Firewalls

- Reverse firewall
  - Monitors outgoing connections
    - Instead of trying to block what's coming in
  - Helps monitor outgoing connection attempts that originates from internal users
    - Filters out unauthorized attempts
  - Companies concerned with how its employees use the Web and other Internet services can use reverse firewall to log connections
    - Block sites that are accessed repeatedly

© Cengage Learning 2014

Firewall Configurations

Configuration	Advantages	Disadvantages
Screening router	Simple, inexpensive; good for home applications if a stateful packet filter is used	Provides only minimal protection; viruses, Trojan programs, and some malformed packets might get through
Dual-homed host	Simple, economical; can provide effective protection if configured correctly	Provides a single point of entry (and fault); the firewall depends entirely on the host computer
Screened host	Provides two layers of protection for home and small-business networks	Provides a single point of entry (and fault); the firewall depends on the host computer and the router protecting it
Screened subnet DMZ	Protects public servers by isolating them from the internal network	Servers in the DMZ are highly vulnerable and need to be hardened
Multiple DMZs/firewalls	Provide layers of protection for a business network	Expensive
Single DMZ/two firewalls	Balance traffic load in high-traffic situations	Expensive
Branch offices/multiple firewalls	Provide protection for all offices in a corporate network as well as central administration	Firewalls must be purchased, installed, and configured at each office location
Reverse firewall	Monitors attacks from inside the network; enables organizations to monitor user activity	Can slow down user access to external networks or other parts of the internal network

Table 10-1 Advantages and disadvantages of firewall configurations

Examining Proxy Servers

- Proxy server
  - Software that forwards packets to and from the network being protected
  - Caches Web pages to speed up network performance

© Cengage Learning 2014

Goals of Proxy Servers

- Original goal
  - Speed up network communications
  - Information is retrieved from proxy cache instead of the Internet
    - If information has not changed at all
- Goals of modern proxy servers
  - Provide security at the Application layer
  - Shield hosts on the internal network
  - Control Web sites users are allowed to access

© Cengage Learning 2014

Proxy Servers Cache a Web Page

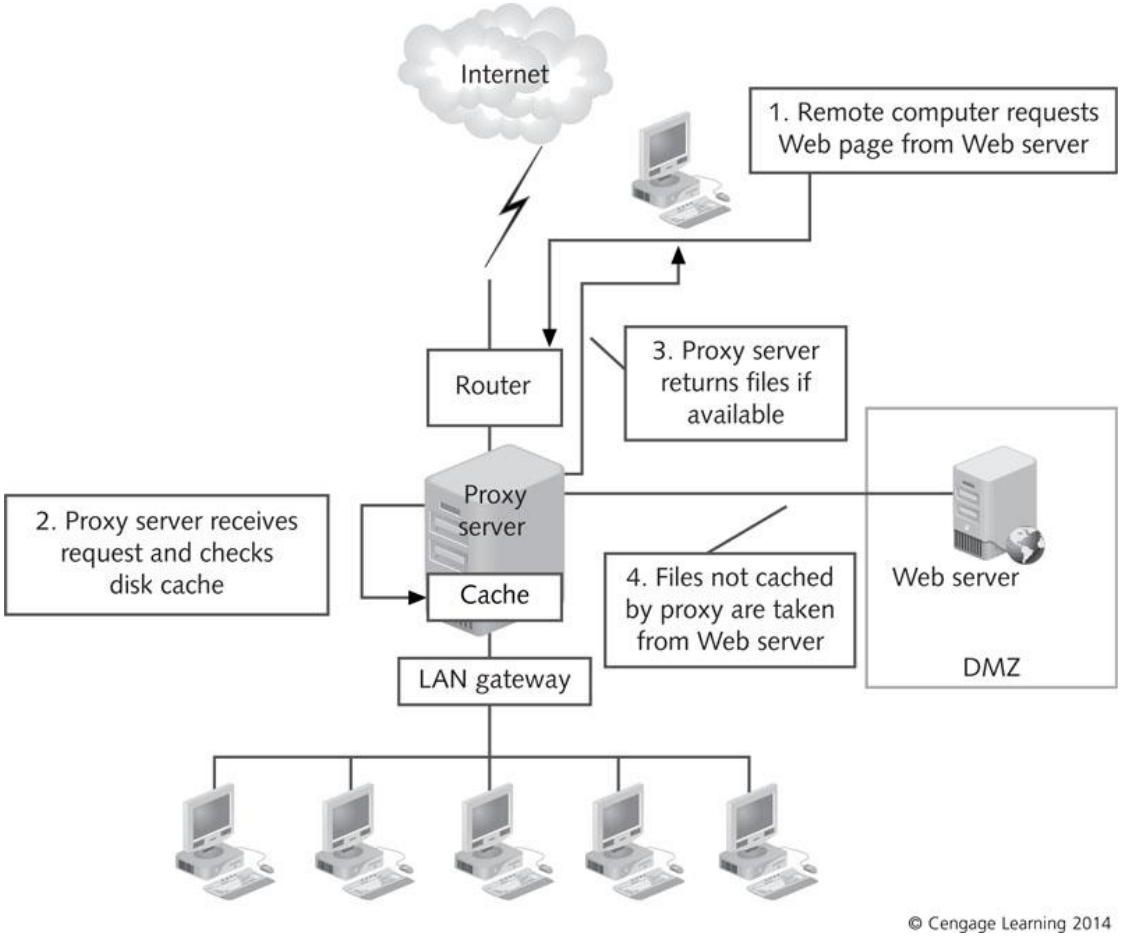


Figure 10-8 Proxy servers cache Web pages and other files

How Proxy Servers Work, Part 1

- Proxy server goal
  - Prevent a direct connection between an external computer and an internal computer
- Proxy servers work at the Application layer
  - Opens the packet and examines the data
  - Decides to which application it should forward the packet
  - Reconstructs the packet and forwards it
    - Replace the original header with a new header
      - Containing proxy's own IP address

© Cengage Learning 2014

Proxy Servers Replace A Source IP Address

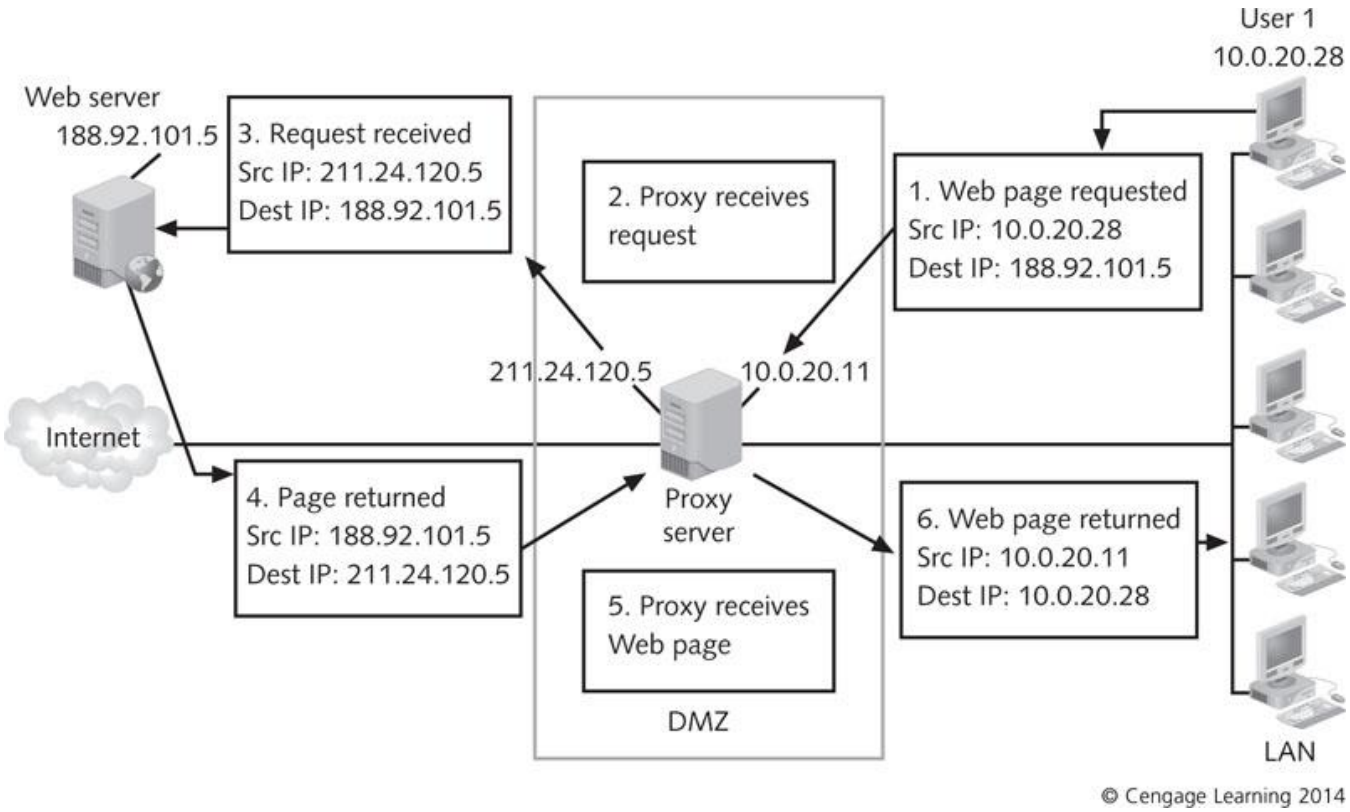


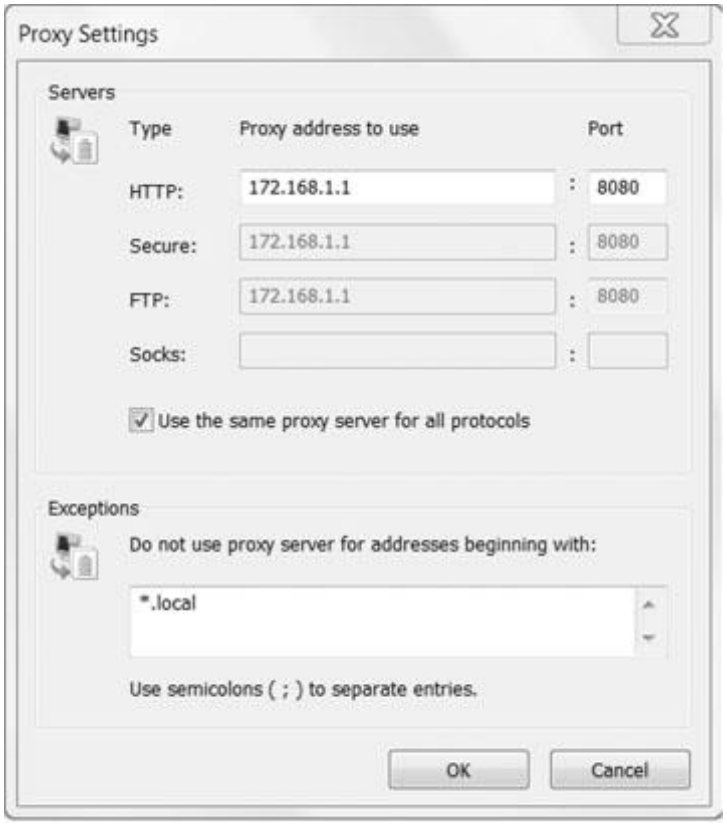
Figure 10-9 Proxy servers replace source IP addresses with their own addresses

How Proxy Servers Work, Part 2

- Proxy server receives traffic before it goes to the Internet
- Client programs are configured to connect to the proxy server instead of the Internet
  - Web browser
  - E-mail applications

© Cengage Learning 2014

Configuring Client Programs to Connect to the Proxy Server



Used with permission of Microsoft Corporation

Figure 10-10 Configuring client programs to connect to the proxy server rather than the Internet

Proxy Server Advantages and Disadvantages

Advantages	Disadvantages
Examines contents of packets and filters on contents	Security can be weak depending on configuration
Shields internal host IP addresses	Can slow down network access
Caches Web pages for faster access	Might require configuration of client programs to use the proxy server
Provides a single point of logging	Provides a single point of failure

Table 10-2 Proxy server advantages and disadvantages

Choosing a Proxy Server, Part 1

- Different proxy servers perform different functions
- Freeware Proxy servers
  - Often described as content filters
  - Most do not have features for business applications
  - Example: Squid for Linux
- Commercial Proxy servers
  - Offer Web page caching, source and destination IP addresses translation, content filtering, and NAT
  - Example: Microsoft Forefront Threat Management Gateway

© Cengage Learning 2014

Choosing a Proxy Server, Part 2

- Proxy Servers That Can Include Firewall Functions
  - Having an all-in-one program simplifies installation, product updating, and management
  - Disadvantages
    - Single point of failure
  - Try to use several software and hardware products to protect your network

© Cengage Learning 2014

Filtering Content

- Proxy servers can open packets and examine data
- Proxy servers can:
  - Filter out content that would otherwise appear in a user's Web browser
  - Block Web sites with content your users should not be viewing
  - Drop executable programs
    - Java applets
    - ActiveX controls

© Cengage Learning 2014

Choosing a Bastion Host

- Security software does not operate on its own
  - Installed on a computer that needs to be as secure as possible
- Bastion host
  - Computer that sits on the network perimeter
  - Has been specially protected through OS patches, authentication, and encryption

© Cengage Learning 2014

General Requirements

- Steps in creating a bastion host
  - Select a machine with sufficient memory and processor speed
  - Choose and install OS and any patches or updates
  - Determine where the bastion host will fit in the network configuration
  - Install services you want to provide
  - Remove services and accounts that aren’t needed.
  - Back up the system and all data on it
  - Conduct a security audit
  - Connect the system to the network

© Cengage Learning 2014

Selecting the Bastion Host Machine, Part 1

- Select familiar hardware and software
  - Not necessarily the latest
- Ideal situation
  - One bastion host for each service you want to provide
    - FTP server, Web server, SMTP server, etc…
- Choosing an Operating System
  - Pick a version that is secure and reliable
  - Check OS Web site for patches and updates

© Cengage Learning 2014

Selecting the Bastion Host Machine, Part 2

- Memory and Processor Speed
  - Memory is always important when operating a server
  - Bastion host might provide only a single service
    - Does not need gigabytes of RAM
  - Match processing power to server load
    - You might have to upgrade or add a processor
- Location on the Network
  - Typically located outside the internal network
    - Combined with packet-filtering devices
  - Multiple bastion hosts are set up in the DMZ

© Cengage Learning 2014

Bastion Hosts Combined with Packet-Filtering Routers

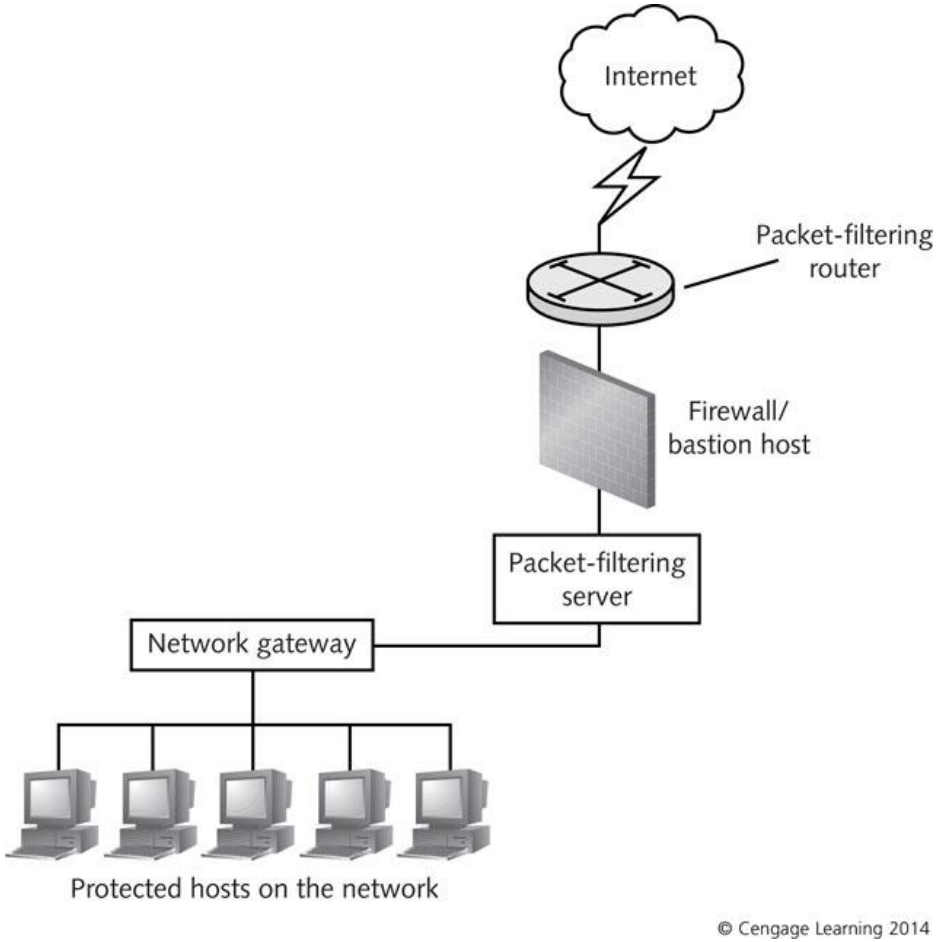


Figure 10-11 Bastion hosts are often combined with packet-filtering routers

Bastion Hosts in the DMZ

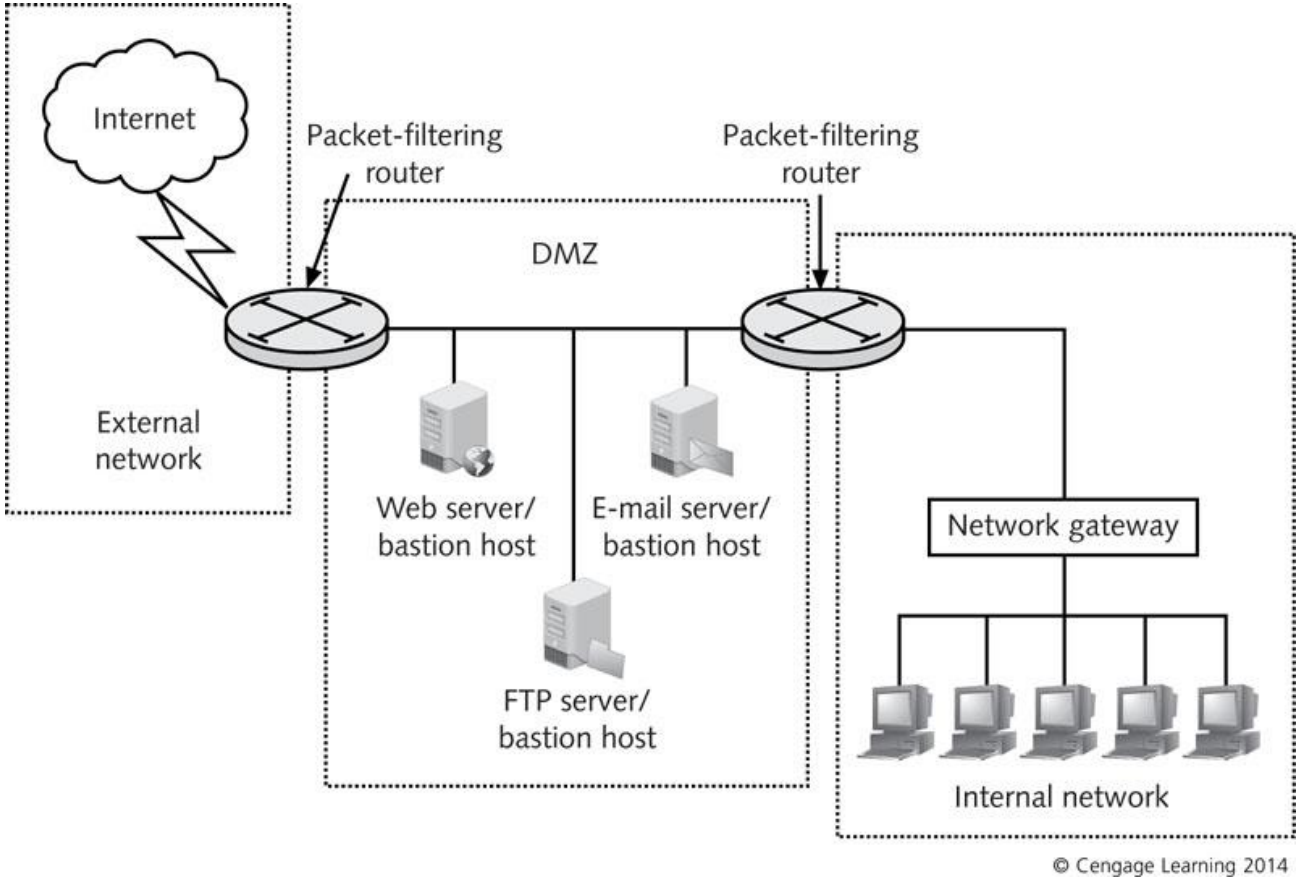


Figure 10-12 Bastion hosts in the DMZ

Hardening the Bastion Host

- The simpler your bastion host is, the easier it is to secure
- Selecting Services to Provide
  - Close unnecessary ports
  - Disable unnecessary user accounts and services
    - Reduces chances of being attacked
  - Disable routing or IP forwarding services
  - Do not remove dependency services
    - System needs them to function correctly
  - Stop services one at a time to check effect on system

© Cengage Learning 2014

Using Honeypots

- Honeypot
  - Computer placed on the network perimeter
  - Attracts attackers away from critical servers
  - Appears real
  - Can be located between the bastion host and internal network
  - Network security experts are divided about honeypots
  - Laws on the use of honeypots are confusing at best
  - Another goal of a honeypot is logging
    - Logs are used to learn about attackers techniques

© Cengage Learning 2014

A Honeypot in the DMZ

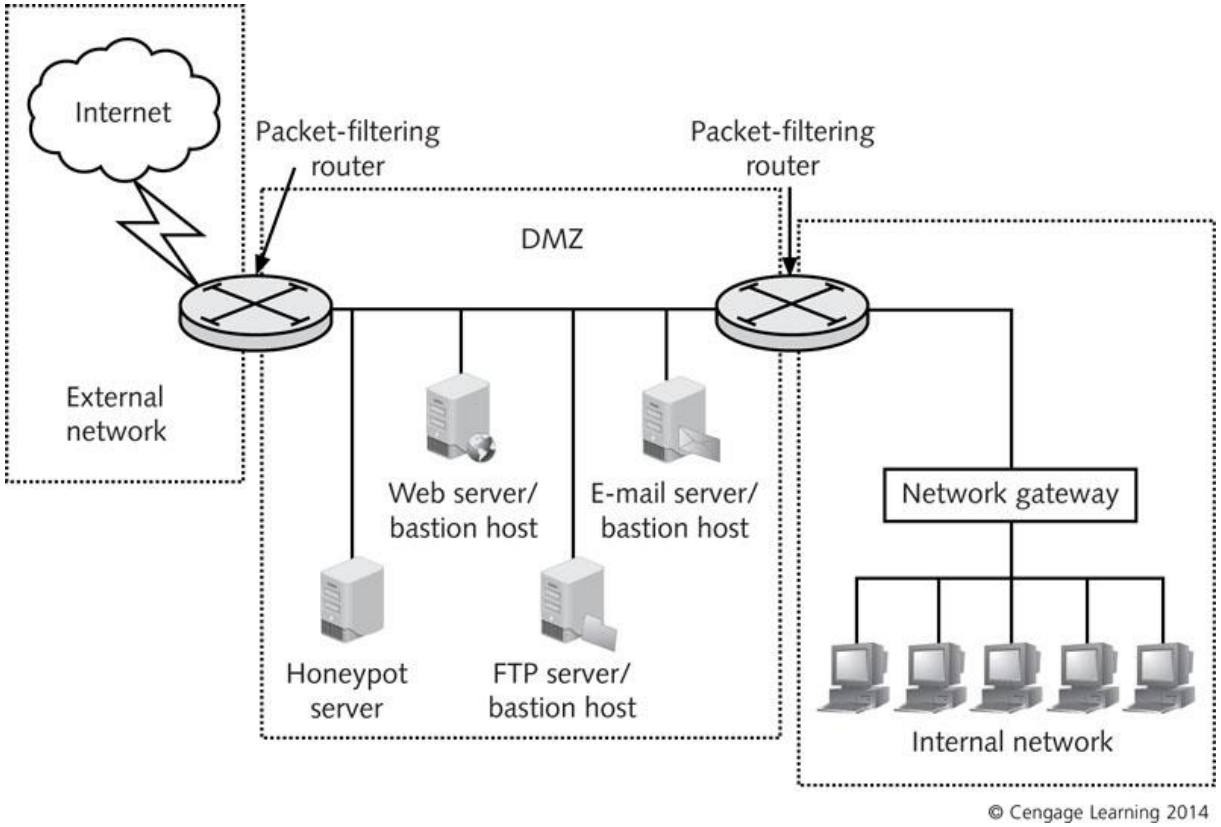


Figure 10-13 A honeypot in the DMZ

Disabling User Accounts

- Default accounts are created during OS installation
  - Some of these account have blank passwords
- Disable all user accounts from the bastion host
  - Users should not be able to connect to it
- Rename the Administrator account
  - Use long, complex passwords

© Cengage Learning 2014

Handling Backups and Auditing

- Essential steps in hardening a computer
  - Backups
  - Detailed recordkeeping
  - Auditing
- Copy log files to other computers in your network
  - Should go through firewall to screen for viruses and other vulnerabilities
- Audit all failed and successful attempts to log on to the bastion host
  - And any attempts to access or change files

© Cengage Learning 2014

Network Address Translation

- Network Address Translation (NAT)
  - Originally designed to help conserve public IP addresses
  - Receives requests at its own IP address and forwards them to the correct IP address
- Allows administrators to assign private IP address ranges in the internal network
- NAT device is assigned a public IP address
- Primary address translation types:
  - One-to-one NAT and many-to-one NAT

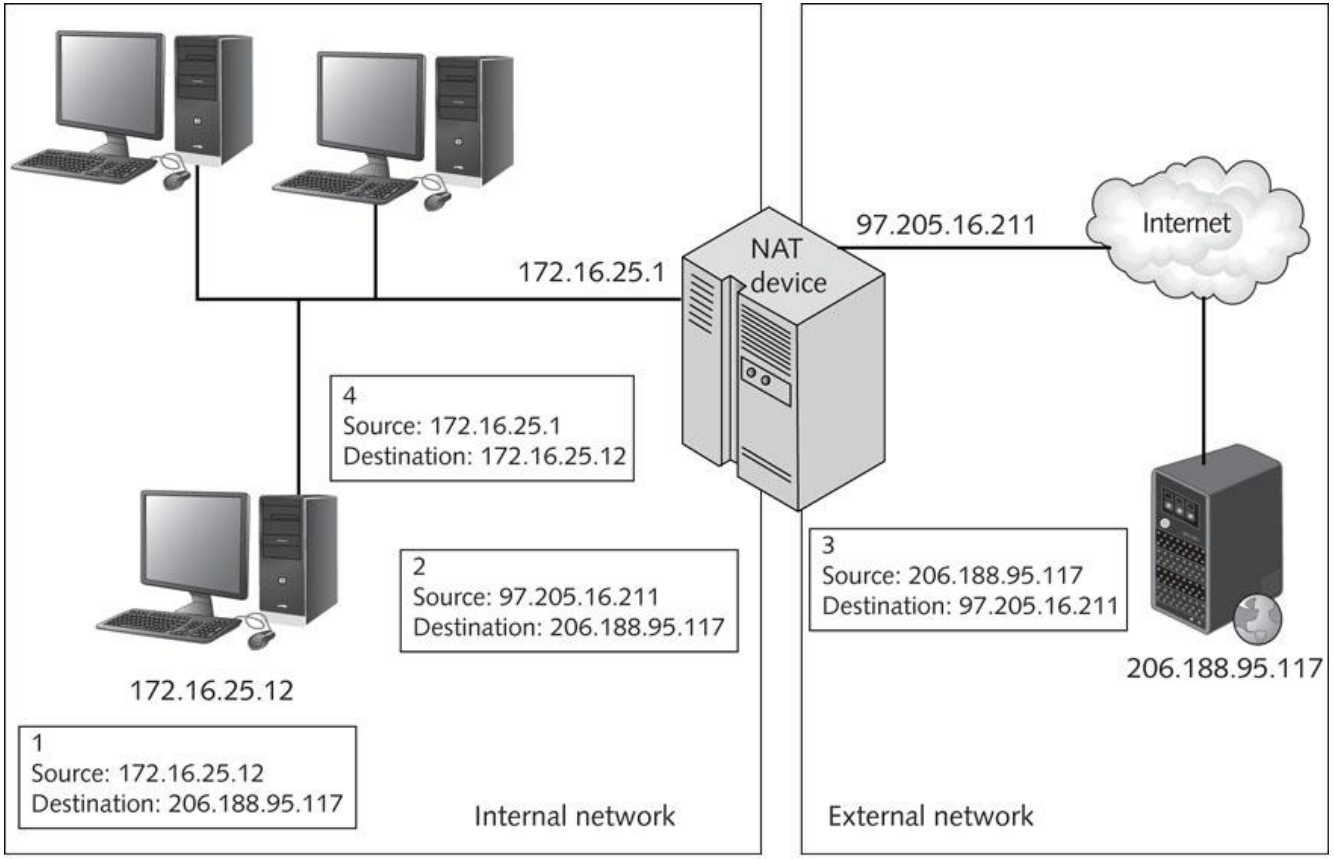
© Cengage Learning 2014

One-to-One NAT

- Process of mapping one internal IP address to one external IP address
  - Internal client sends packets (destined for an external host) to its default gateway on the NAT device
  - NAT device repackages the packet so its public interface appears to be the source and sends to external host
  - External host responds to NAT device
  - NAT device repackages response and sends it to the internal host

© Cengage Learning 2014

Example of a One-to-One NAT



© Cengage Learning 2014

Figure 10-15 One-to-one NAT

Many-to-One NAT

- Uses TCP and UDP port addresses to distinguish between internal clients
  - Allows many internal clients to use the same single public NAT interface simultaneously
- Disadvantages:
  - You can hide only so many clients behind a single IP address
    - Performance degrades as number increases
  - Does not work with some types of VPNs
  - Uses only a single public IP address
    - Cannot provide other services, such as a Web server

© Cengage Learning 2014

Example of a Many-to-One NAT

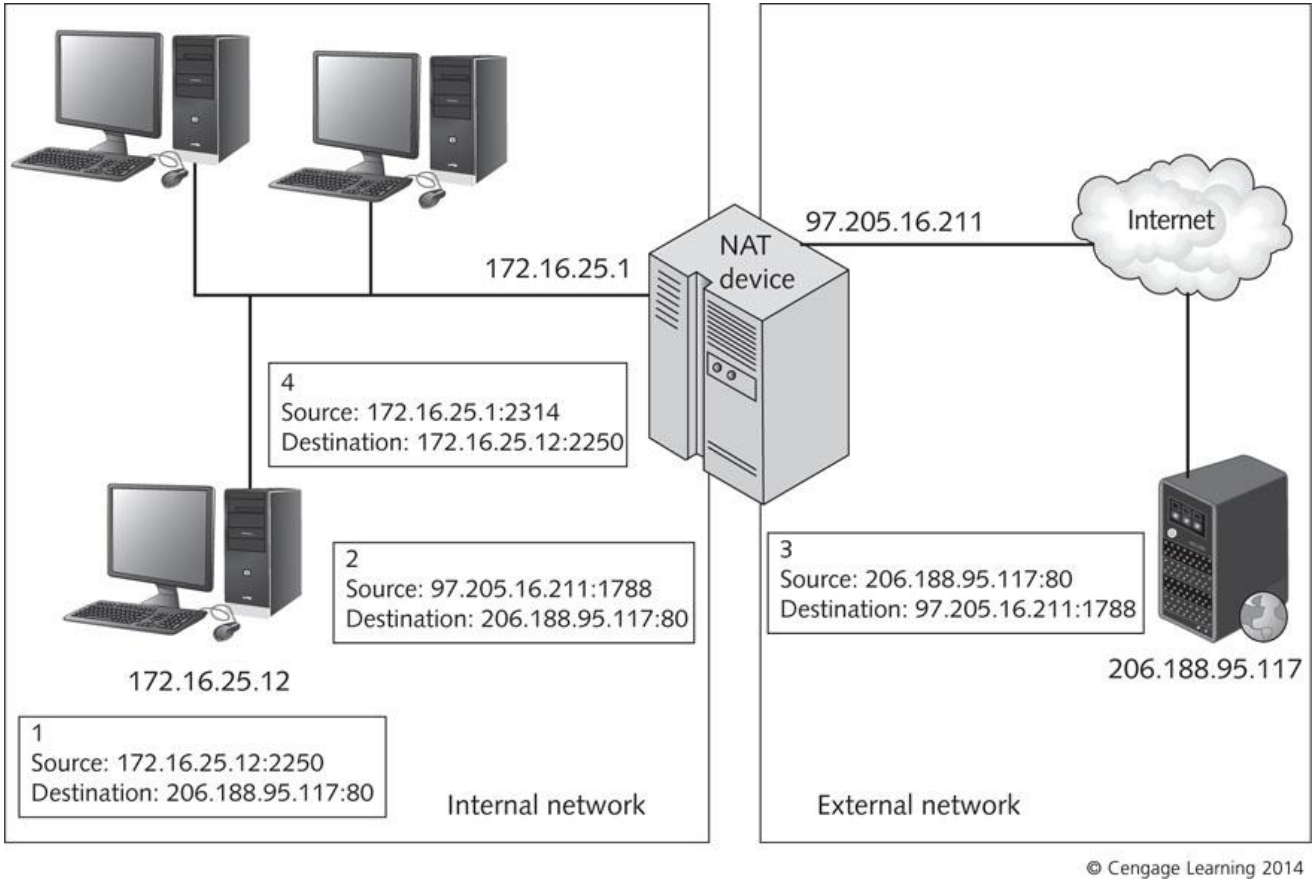


Figure 10-16 Many-to-one NAT

Firewall Configuration Example, Part 1

- Basics of configuring a Cisco ASA 5505 firewall:
  - Rollover cable is connected to the management PC's COM 1 port and firewall's Console port
  - A terminal emulator (PuTTY) is used to make the command-line connection
  - Command prompt is "ciscoasa" by default and enable password is blank
    - Type **enable** and hit enter at password prompt
  - The **show switch vlan** command shows that all eight ports are placed in VLAN 1 by default

© Cengage Learning 2014

Firewall Configuration Example, Part 2

- Basics of configuring a Cisco ASA 5505 firewall (cont'd):
  - Use the **configure terminal** command to switch to global configuration mode so that you can configure the firewall
  - Type **hostname SanFrancisco** to name firewall
  - To assign a strong password, type **enable password T%imPwa0)gi**
  - To configure interfaces, type interface (type of interface) (interface number)
    - **interface ethernet 0/0**

© Cengage Learning 2014

Firewall Configuration Example, Part 3

- Basics of configuring a Cisco ASA 5505 firewall (cont'd):
  - Commands to use when naming VLANs
    - **interface VLAN1**
    - **nameif LAN**
    - **security-level 100**
    - **ip address 192.168.1.205 255.255.255.0**
    - **exit**
  - To view IP address information:
    - **show ip address**

© Cengage Learning 2014

Firewall Configuration Example, Part 4

- Basics of configuring a Cisco ASA 5505 firewall (cont'd):
  - To save configuration changes:
    - **copy running-config startup-config**
  - If you have a TFTP server, you should copy the configuration there
    - **copy startup-config tftp**
  - To verify IP interfaces:
    - **show interface ip brief**
  - To enable routing using the RIP routing protocol
    - **router rip** followed by network numbers

© Cengage Learning 2014

Firewall Configuration Example, Part 5

- Basics of configuring a Cisco ASA 5505 firewall (cont'd):
  - To save configuration changes:
    - **copy running-config startup-config**
  - If you have a TFTP server, you should copy the configuration there
    - **copy startup-config tftp**
  - To verify IP interfaces:
    - **show interface ip brief**
  - To enable routing using the RIP routing protocol
    - **router rip** followed by network numbers

© Cengage Learning 2014

Summary, Part 1

- Firewall design includes planning location for firewall placement
- You can use multiple firewalls when you need multiple DMZs or to provide load balancing
- Proxy servers cache Web pages to speed up network performance
  - Today, can perform firewall and NAT tasks as well
- Bastion hosts are computers that are accessible to untrusted clients
  - Such as Web server, e-mail servers, and proxy servers

© Cengage Learning 2014

Summary, Part 2

- Network Address Translation (NAT)
  - Used to protect internal clients from direct access by untrusted, external hosts
  - Decreases need for public IP addresses
- Many of the same commands used to configure Cisco routers and switches are also applicable on Cisco firewalls

© Cengage Learning 2014